

Supplementary material for CONTAINER: Bounding Credential-Compromise Impact in IEEE 2030.5 DER Systems

Huan Bui

University of North Carolina at Charlotte, Charlotte, NC, USA

SM.1 Standards quotations supporting the claim matrix

The manuscript’s standards table cites a free source for each claim. This section reproduces the load-bearing text verbatim, so a reader can check the reading without obtaining any document that must be purchased. All quotations are from Sandia National Laboratories, *Recommendations for Trust and Encryption in DER Interoperability Standards*, SAND2019-1490, whose full text is publicly available from OSTI.

Certificate lifetime and revocation.. From §4.1:

“The IEEE 2030.5/CSIP PKI is different than other PKI’s in the use of non-expiring certificates and the explicit prohibition of CRL and OCSP. Once issued, a device certificate has an indefinite lifetime, so it is always valid. . . . If the device’s private key is compromised, the device certificate cannot be revoked. . . . In fact, IEEE 2030.5 prohibits their use. This means that Certificate Authorities (CA) shall not maintain CRLs or run OCSP servers, and clients and servers shall not check for CRLs or OCSP servers to verify certificate validity.”

Email address: `hbui11@charlotte.edu` (Huan Bui)

The prohibition is scoped, which is why the manuscript qualifies it. From §6.4, quoting the standard’s own certificate-management statements:

“The phrase ‘Optional OCSP’ means that the server device (and optionally, the client device) may utilize Online Certificate Status Protocol as an additional mechanism to determine if a certificate has been revoked. **OCSP may only be used to verify non-IEEE 2030.5 certificates.**”

Local allow/deny listing, and its limits.. From §4.1 and §4.1.2:

“This does not preclude servers or clients from maintaining or obtaining their own list of blacklisted or whitelisted devices if the operator prefers.”

“A blacklist is essentially a local CRL but without the process, rigor and verification behind its issuance.”

“With fragmented blacklists and policies, it is possible for a stolen device certificate that was disallowed in one region to be used in a different region to gain access because it was only locally blacklisted.”

A short-lived operational credential is permitted.. From §6.4:

“Inverter manufacturers strictly following these guidelines are **not required to limit the life of a device certificate** or to validate IEEE 2030.5 certificates using OCSP or CRLs.”

“(1 year certificate life is the usual recommended renewal interval).”

This is why the manuscript claims no novelty for the short lifetime itself: it is recommended practice in the analysis of record, and permitted rather than prohibited by the profile.

The adversary the design targets.. From §6.4:

“If a manufacturer decides not to implement certificate revocation and replacement, for a critical period an adversary could potentially extract a private key from a device and masquerade as the legitimate device without other nodes being aware of the device compromise.”

What no accessible source states.. Searched for and not found, in SAND2019-1490 or in the CSIP Implementation Guide: any statement that adding an identity to a deny list terminates that identity’s *established* mutual-TLS session; any statement that it cancels an already-issued `DERControl`; and any mechanism by which an authorization can bound the *value* a control may take rather than which function may be invoked. The first two are the premise of the manuscript’s containment argument, and the third is why its numeric authorization is placed above `FunctionSetAssignments` rather than inside it.

SM.2 The IEEE 9500 non-convergence, in full

The manuscript states that the PNNL 9500-node system did not converge in our build and therefore contributes no reported number. This section names the failure mode, so the absence is an explained negative result rather than a silent omission.

The failure is in the *base case*, with no attack and no PV of ours placed: the model’s own shipped driver, unaltered, returns `Converged = False` with an empty error description and every bus per-unit magnitude reading zero — the solution collapses rather than missing tolerance. It reproduces at 1000 iterations, under both the normal and Newton algorithms, and with feeder controls enabled and disabled, so it is neither a control-loop oscillation nor an iteration-budget shortfall. Our build is DSS C-API 0.14.5 / DSS-Python 0.15.7 / OpenDSSDirect.py 0.9.4 on macOS arm64.

We did not resolve it and we do not attribute it, having had no second OpenDSS build to discriminate a defect on our side from one in the model. The consequence is that the 9500 system supports nothing in the manuscript. Cross-feeder generality rests instead on the IEEE 8500-node and IEEE 123-bus feeders,

which every physical result in the paper uses, and which differ in voltage level, topology, regulator structure and stiffness.

SM.3 Inventory of the runs behind the manuscript

Table 1 inventories every run, so no experiment’s scale has to be inferred from prose. Seeds are paired across arms within an experiment. “Arms” counts independent feeder compiles; “solves” counts power-flow solutions, since an arm that searches an authorization set or steps a horizon contains many.

Table 1: Runs behind the manuscript. The calibration and the two post-hoc sweeps are labelled as such; neither supports a hypothesis test.

Experiment	Seeds	Arms	Solves	Status
Hosting-capacity calibration	5	560	1120	calibration
Authorization-shape sweep	20	2520	18000	confirmatory
Lifecycle horizon experiment	20	40	48000	confirmatory
Attacker action-space scan	20	60	2760	confirmatory
Reliance resolution sweep	20	160	1280	post-hoc
Lifecycle parameter sensitivity	—	60	—	post-hoc, model only
Credential-service invariants	1	10	—	confirmatory
Overhead microbenchmarks	500 iterations	4	—	confirmatory
Availability fault injection	3 policies	3	—	confirmatory

The authorization-shape sweep is 2 feeders $\times$ 3 penetration rungs $\times$ 11 authorization sets $\times$ 2 control primitives $\times$ 20 paired seeds, less the read-only set, which has no fixed-setpoint realisation. The lifecycle experiment is 2 operating states $\times$ 20 paired seeds $\times$ 19 lifecycle arms plus a paired legitimate arm, each stepped over a 60-minute horizon.

SM.4 Result files and the claims they support

Every numeral in the manuscript is checked against these files by `check_numbers.py`, which fails if a reported number cannot be located in them.

Table 2: Released result files and the manuscript claims each supports.

File	Supports
hosting_capacity.json	operating ladder, compliance criterion
authz_shape.json	authorization-set families, H1, H2, H3
shape_contrasts.json	paired H1/H2/H3 estimates and intervals
reliance_resolution.json	intermediate rungs of the reliance curve
lifecycle_physical.json	horizon time series, all lifecycle arms
lifecycle_contrasts.json	paired lifecycle contrasts, Holm-corrected
lifecycle_sensitivity.json	parameter sensitivity of the exposure window
attackers.json	five attacker models, full action-space scan
attacker_detectors.json	dual-detector analysis, dual-evading optimum
retention.json	compromise-class retention expectations
credsvc.json	the ten security invariants
hwkey.json	the failed hardware-keystore attempt
controlmode.json	feeder controls active under static
availability.json	safe-mode availability under verifier outage